■# Relatório de Governança, Segurança e Ética no Uso de IA

Projeto: Task Analyser

Disciplina: Bootcamp III — CEUB

Autor: Sávio Arbuês Abrahão Nery

Repositório: https://github.com/savio-n/sdd-task-analyser

Data: 25 de outubro de 2026

1. Introdução

O projeto Task Analyser utiliza desenvolvimento orientado por especificações (Spec-Driven Development — SDD) para estruturar a implementação e a validação de uma solução de análise de tarefas em Python. Assistentes de Inteligência Artificial podem apoiar atividades de implementação, documentação e revisão, mas seu uso exige controles que reduzam riscos técnicos, éticos e de segurança.

Este relatório apresenta os principais riscos associados ao uso de IA no desenvolvimento do projeto e as medidas adotadas para preservar a rastreabilidade, a qualidade técnica e a responsabilidade humana.

2. Governança do desenvolvimento

A governança do projeto é baseada em uma hierarquia explícita de requisitos. A especificação funcional e técnica, os cenários de aceitação e o arquivo CONTEXT_RULES.md orientam a implementação.

O processo de desenvolvimento contempla:

• Definição e consulta da especificação.

• Implementação orientada pelos requisitos.

• Execução dos testes automatizados com pytest.

• Validação humana dos resultados.

• Versionamento das alterações com Git.

• Integração contínua por meio do GitHub Actions.

• Verificação da execução em ambiente Docker.

As alterações são registradas no histórico do Git, permitindo identificar versões e revisar decisões técnicas. O uso de branches também possibilita separar mudanças e facilitar a revisão antes de sua integração.

3. Risco de alucinações da Inteligência Artificial

Modelos de IA podem produzir informações incorretas, inventar requisitos, sugerir bibliotecas desnecessárias ou apresentar código aparentemente correto que não respeita a especificação.

No Task Analyser, esses riscos são especialmente relevantes quando envolvem regras de validação, métricas, campos de entrada e saída, tratamento de exceções e comportamento da função pública analyze_tasks.

Para reduzir esses riscos, foram estabelecidas as seguintes medidas:

• A especificação do projeto é a fonte de verdade para o comportamento esperado.

• O arquivo `CONTEXT_RULES.md` limita alterações arbitrárias e orienta os assistentes de IA.

• Os testes automatizados verificam os cenários de aceitação definidos.

• As falhas devem ser investigadas em relação à especificação, sem modificar testes apenas para aprovar uma implementação incorreta.

• Ambiguidades devem ser identificadas e encaminhadas para decisão humana, em vez de resolvidas por suposições silenciosas.

A aprovação dos testes aumenta a confiança na implementação, mas não comprova, isoladamente, a ausência de todos os defeitos possíveis.

4. Segurança técnica

O projeto adota medidas de segurança compatíveis com seu escopo acadêmico:

• Dependências declaradas em `requirements.txt`.

• Execução isolada dos testes em um contêiner Docker.

• Automação de testes e construção da imagem no GitHub Actions.

• Proibição explícita de inserir credenciais, tokens ou segredos no código.

• Restrição à adição de serviços externos e funcionalidades não solicitadas.

• Uso do histórico de versionamento para rastrear alterações.

A utilização de contêineres melhora a reprodutibilidade do ambiente, mas não elimina todos os riscos de segurança. Imagens-base e dependências ainda precisam de manutenção e atualização. Este projeto não deve ser interpretado como uma auditoria formal de segurança.

5. Ética e responsabilidade humana

A IA é utilizada como ferramenta de apoio, e não como autoridade final sobre requisitos, qualidade ou decisões do projeto.

Os princípios éticos adotados incluem:

• **Responsabilidade:** a aprovação final da implementação cabe ao responsável humano.

• **Transparência:** as regras de desenvolvimento e validação são documentadas.

• **Integridade acadêmica:** o uso de ferramentas de IA não substitui a compreensão, a revisão e a apresentação autoral do trabalho.

• **Confiabilidade:** resultados gerados por IA devem ser confrontados com requisitos e testes.

• **Minimização de dados:** não devem ser inseridos segredos ou dados pessoais desnecessários em ferramentas ou arquivos do projeto.

• **Proporcionalidade:** funcionalidades devem permanecer dentro do escopo definido, sem ampliação arbitrária.

A utilização responsável exige que o autor compreenda as decisões incorporadas ao código e consiga explicar suas justificativas e limitações.

6. Testes e evidências de validação

O projeto utiliza pytest para verificar os cenários de aceitação e Docker para executar os testes em um ambiente isolado.

Na validação local registrada durante o desenvolvimento, os seis testes do harness foram aprovados dentro do contêiner Docker. Os cenários incluem análise bem-sucedida, inconsistências de datas, entrada vazia, prioridade inválida, alerta por média elevada de CPU e tarefas pendentes.

O pipeline de integração contínua foi configurado para executar os testes e construir e executar a imagem Docker em eventos de push e pull request direcionados às branches main e develop.

A aprovação da execução no GitHub Actions deve ser confirmada no histórico de execuções do repositório. A configuração do pipeline, por si só, não comprova que todas as execuções remotas foram aprovadas.

7. Limitações e melhorias futuras

O projeto possui escopo acadêmico e seus testes cobrem os cenários especificados, não necessariamente todas as entradas possíveis. Também não foi realizada, neste relatório, uma auditoria independente de segurança, privacidade ou resistência a ataques.

Como melhorias futuras, recomenda-se:

• ampliar os testes de fronteira conforme a especificação;

• verificar vulnerabilidades nas dependências e na imagem-base;

• proteger segredos por meio dos mecanismos apropriados do ambiente de CI;

• revisar periodicamente as permissões e os workflows;

• documentar incidentes e decisões técnicas relevantes;

• avaliar as alterações propostas por IA antes de incorporá-las.

Essas recomendações são propostas de evolução e não declarações de funcionalidades já implementadas.

8. Conclusão

O Task Analyser aplica uma abordagem de desenvolvimento na qual especificações, testes automatizados, revisão humana, versionamento e integração contínua atuam como mecanismos complementares de controle.

A IA pode acelerar o desenvolvimento, mas também pode introduzir erros, interpretações incorretas e riscos. Por isso, seus resultados devem ser tratados como propostas sujeitas a verificação. A especificação orienta o comportamento esperado, os testes fornecem evidências de validação e a decisão final permanece sob responsabilidade humana.

A combinação desses controles contribui para um processo de desenvolvimento mais rastreável, reprodutível e responsável, sem pressupor que a automação elimine todos os riscos.